



BluCoop - Cooperativa de Crédito

POLÍTICA DE SEGURANÇA DA INFORMAÇÃO (PSI)

PSI-2026

CONTROLE DE VERSÃO

	Versão	Data de Publicação	Classificação	Revisão
	001-PSI-2026	13-06-2026	Interna	Lucas Lima

SUMÁRIO

CONTROLE DE VERSÃO.....	2
1 INTRODUÇÃO.....	6
1.1 Objetivo.....	7
1.2 Escopo.....	7
2 PRINCÍPIOS DE SEGURANÇA.....	8
2.1 Confidencialidade.....	8
2.2 Integridade.....	8
2.3 Disponibilidade.....	9
3 CLASSIFICAÇÃO DA INFORMAÇÃO.....	10
4 GERENCIAMENTO DE ACESSO.....	12
4.1 Controle de Acesso.....	12
4.2 Autenticação.....	12
4.3 Autorização.....	13
5 SEGURANÇA FÍSICA E AMBIENTAL.....	14
5.1 Modelo de Responsabilidade Compartilhada.....	14
Ambientes e responsabilidades.....	14
5.2 Segurança do Escritório Central e Servidores Físicos.....	15
Controle de acesso físico.....	15
Proteção dos servidores e equipamentos.....	15
Monitoramento do ambiente.....	15
5.3 Segurança no Ambiente de Trabalho Remoto.....	16
Diretrizes para o home office.....	16
Proteção dos equipamentos corporativos.....	16
5.4 Política de Mesa Limpa e Tela Limpa.....	16
Mesa limpa.....	16
Tela limpa.....	17
5.5 Descarte Seguro de Documentos e Dispositivos.....	17
6 SEGURANÇA DE REDES E COMUNICAÇÕES.....	18
6.1 Arquitetura e Segmentação de Rede.....	18
Princípios de arquitetura segura.....	18
Segmentação de rede.....	18
6.2 Firewalls e Controle de Tráfego.....	19

Implantação e configuração de firewalls.....	19
Sistemas de detecção e prevenção de intrusão.....	19
6.3 Proteção das Comunicações entre Unidades e Acesso Externo.....	19
Segurança das comunicações entre unidades.....	19
VPN para acesso remoto.....	20
Proteção dos serviços críticos de rede.....	20
6.4 Proteção de Comunicações e Protocolos Seguros.....	20
Criptografia em trânsito.....	21
Segurança das comunicações de voz.....	21
6.5 Monitoramento e Registro de Rede.....	21
Logs e registros de rede.....	21
Monitoramento contínuo da rede.....	22
6.6 Gestão de Equipamentos de Rede.....	22
Hardening de dispositivos de rede.....	22
Gestão de mudanças na rede.....	22
7 GESTÃO DE INCIDENTES DE SEGURANÇA.....	24
7.1 Processo de Gestão de Incidentes.....	24
7.1.1 Identificação.....	24
7.1.2 Registro.....	24
7.1.3 Classificação.....	25
7.1.4 Resposta.....	25
7.1.5 Contenção.....	25
7.1.6 Erradicação.....	25
7.1.7 Recuperação.....	26
7.1.8 Documentação.....	26
7.2 Fluxo de Resposta a Incidentes.....	26
7.3 Papéis e Responsabilidades.....	27
7.4 Níveis de Criticidade.....	27
7.5 Canais de Comunicação.....	28
7.6 Registro de Evidências.....	28
7.7 Plano de Recuperação.....	29
7.8 Lições Aprendidas.....	30
7.9 Relação com a Infraestrutura de Rede.....	30
8 CONSCIENTIZAÇÃO E TREINAMENTO EM SEGURANÇA.....	31
8.1 Treinamentos Periódicos.....	31
8.2 Campanhas de Conscientização.....	31
8.3 Boas Práticas no Uso de Senhas, E-mail, Internet e Dispositivos.....	32
8.4 Prevenção contra Phishing e Engenharia Social.....	32
8.5 Orientações para Uso Seguro da Rede Corporativa.....	33
8.6 Responsabilidades dos Usuários.....	33
8.7 Avaliação de Aprendizagem.....	34

8.8 Relação com os Mecanismos de Segurança.....	34
9 AVALIAÇÃO E MELHORIA CONTÍNUA.....	35
9.1 Auditorias de Segurança.....	35
Programa de auditorias.....	35
Escopo das auditorias.....	35
Auditorias internas e externas.....	35
Tratamento dos resultados.....	36
9.2 Revisão de Políticas e Procedimentos.....	36
Periodicidade e gatilhos.....	36
Processo de revisão.....	36
Documentação e comunicação.....	36
Treinamento após revisões.....	37
9.3 Análise de Riscos.....	37
Metodologia de avaliação.....	37
Identificação de ativos e ameaças.....	37
Avaliação de impacto e probabilidade.....	37
Tratamento dos riscos.....	37
Revisão contínua dos riscos.....	38
9.4 Medição de Desempenho.....	38
Programa de métricas.....	38
Indicadores recomendados.....	38
Monitoramento contínuo.....	38
Relatórios de desempenho.....	39
Uso dos resultados para melhoria contínua.....	39
10 CONFORMIDADE LEGAL E REGULATÓRIA.....	40
10.1 Conformidade com Leis e Regulamentações.....	40
Resoluções do Banco Central.....	40
Requisitos adicionais da Resolução BCB n.º 4.893/2021.....	40
Lei Geral de Proteção de Dados (LGPD).....	41
Sigilo bancário e leis setoriais.....	41
Integração das obrigações.....	41
10.2 Gerenciamento de Vulnerabilidades e Patches.....	41
Processo de gerenciamento de vulnerabilidades.....	42
Princípios de patch management.....	42
Redução de vulnerabilidades e inventário de ativos.....	42
Ciclo de correção e teste.....	42
Integração com a governança.....	43
11 RESPONSABILIDADES.....	44
11.1 Direção.....	44
11.2 Equipe de Tecnologia da Informação.....	44
11.3 Equipe de Segurança da Informação.....	44

11.4 Colaboradores.....	45
11.5 Cooperados.....	45
11.6 Fornecedores e Parceiros Externos.....	45
REFERÊNCIAS.....	46
GLOSSÁRIO.....	48

1 INTRODUÇÃO

A segurança da informação é um dos pilares fundamentais da governança de qualquer instituição financeira. Para cooperativas de crédito, cujas operações envolvem dados sensíveis de cooperados, fluxos financeiros e sistemas interconectados entre múltiplas unidades, a proteção das informações assume caráter ainda mais estratégico. Nesse contexto, a BluCoop cooperativa de crédito regional com atuação no Vale do Itajaí, Santa Catarina reconhece a necessidade de formalizar e consolidar suas diretrizes de segurança em um documento abrangente e estruturado.

A BluCoop, fundada em 1985 a partir da iniciativa de trabalhadores da região de Blumenau, conta hoje com aproximadamente 120 mil cooperados, cinco filiais e cerca de 116 colaboradores distribuídos entre a matriz e as unidades regionais. A cooperativa opera com serviços centralizados na matriz, unidades regionais interligadas à sede e colaboradores em regime de acesso remoto. Esse ambiente distribuído, aliado à adoção de um modelo híbrido de trabalho na matriz, amplia a superfície de exposição a ameaças e demanda controles robustos em múltiplas camadas.

O presente documento estabelece a Política de Segurança da Informação (PSI) da BluCoop, com o objetivo de orientar as práticas, os controles e as responsabilidades relacionadas à proteção das informações em todas as suas dimensões: física, lógica, humana e regulatória. A política foi elaborada com base nas melhores práticas internacionais, em especial a ISO/IEC 27001:2022 e a série de publicações especiais do NIST, além das exigências regulatórias impostas pelo Banco Central do Brasil por meio das Resoluções CMN n.º 4.658/2018 e n.º 4.893/2021, e da Lei Geral de Proteção de Dados Pessoais (LGPD), Lei n.º 13.709/2018.

A estrutura desta política segue o modelo estabelecido no template institucional disponibilizado pela Pontifícia Universidade Católica de Minas Gerais, abrangendo os seguintes tópicos: princípios de segurança; gerenciamento de acesso; segurança física e ambiental; segurança de redes e comunicações; gestão de incidentes; conscientização e treinamento; avaliação e melhoria contínua; conformidade legal e regulatória; e responsabilidades.

1.1 Objetivo

Esta política tem como objetivo estabelecer as diretrizes, os requisitos e as responsabilidades para garantir a segurança da informação na BluCoop, protegendo os ativos informacionais da cooperativa contra ameaças internas e externas, acidentais ou deliberadas, de forma a preservar a confidencialidade, a integridade e a disponibilidade das informações.

1.2 Escopo

Esta política aplica-se a todos os colaboradores, estagiários, prestadores de serviço, fornecedores e parceiros que acessam, processam, transmitem ou armazenam informações e ativos tecnológicos da BluCoop, abrangendo todas as unidades da cooperativa matriz de Blumenau e filiais de Gaspar, Timbó, Indaial, Pomerode e Ascurra e os ambientes de trabalho remoto dos colaboradores da matriz.

2 PRINCÍPIOS DE SEGURANÇA

Esta seção do documento estabelece os pilares fundamentais que orientam a proteção das informações e dos ativos tecnológicos da BluCoop, em conformidade com as diretrizes da ISO/IEC 27001 [4] e com as exigências regulatórias do Banco Central do Brasil [2][18].

2.1 Confidencialidade

A confidencialidade assegura que as informações da BluCoop sejam acessadas exclusivamente por pessoas ou sistemas devidamente autorizados, conforme preconizado pela ISO/IEC 27002 [5] e pela LGPD [3]. Em uma cooperativa financeira que opera dados sensíveis de aproximadamente 120 mil cooperados distribuídos entre matriz e cinco filiais, a proteção contra acessos indevidos e vazamentos é condição essencial para a preservação da confiança institucional.

Para mitigar os riscos de exposição de dados, a garantia da confidencialidade repousa primordialmente sobre uma rígida governança de identidades e na proteção criptográfica dos ativos. No ambiente interno, o controle de acesso lógico deve ser centralizado, garantindo que a visibilidade e a manipulação de dados financeiros e cadastrais fiquem estritamente restritas às áreas e aos perfis autorizados. Para garantir a segurança dos dados em trânsito, o fluxo de comunicação de colaboradores em regime híbrido deve ser obrigatoriamente protegido por criptografia, impedindo a interceptação de tráfego corporativo. Nos ambientes em nuvem, a proteção das informações deve ser reforçada por controles que bloqueiem conexões externas diretas aos repositórios de dados e por mecanismos de autenticação forte para acesso administrativo. De maneira complementar à segurança lógica, deve-se adotar o isolamento de perímetro nas agências, com separação entre a rede corporativa e a rede de acesso público destinada a visitantes.

2.2 Integridade

A integridade garante que as informações da BluCoop permaneçam completas, precisas e não adulteradas ao longo de todo o seu ciclo de vida, conforme estabelecido pela ISO/IEC 27002 [5]. Para uma instituição financeira sujeita às normas do Conselho Monetário Nacional [2], a modificação não autorizada de registros cadastrais, transações ou configurações de sistemas pode comprometer operações de crédito e gerar impactos regulatórios severos.

O repositório central de dados da cooperativa concentra os registros mais sensíveis da instituição e deve ser acessível apenas por sistemas e usuários formalmente autorizados. A transferência de arquivos entre unidades deve ocorrer por canais controlados, impedindo a circulação de versões inconsistentes de documentos corporativos. As configurações das estações de trabalho devem permanecer padronizadas por meio de políticas aplicadas por perfil departamental, impedindo alterações não autorizadas no ambiente operacional dos colaboradores. O monitoramento contínuo complementa esses controles ao identificar em tempo real comportamentos anômalos e desvios nas métricas dos sistemas.

2.3 Disponibilidade

A disponibilidade assegura que os sistemas e serviços da BluCoop estejam acessíveis sempre que necessários, em conformidade com as exigências de continuidade operacional da Resolução BCB nº 85/2021 [18] e com as boas práticas do NIST Cybersecurity Framework [19]. Interrupções nos sistemas de crédito, Internet Banking ou comunicação interna geram impactos financeiros, operacionais e reputacionais diretos.

A arquitetura de rede deve ser projetada de forma resiliente, garantindo que falhas isoladas em dispositivos ou filiais específicas não comprometam o restante da infraestrutura. Cada filial deve manter capacidade de operação local, assegurando que quedas temporárias da conexão com a matriz não interrompam a conectividade local das agências. No ambiente em nuvem, os serviços essenciais devem operar com redundância e replicação automática, garantindo que os recursos compartilhados permaneçam acessíveis mesmo diante de instabilidades pontuais. O monitoramento ativo, com alertas automáticos para serviços críticos, acelera o tempo de resposta da equipe de TI diante de qualquer cenário de indisponibilidade.

3 CLASSIFICAÇÃO DA INFORMAÇÃO

A BluCoop classifica as informações sob sua responsabilidade de acordo com seu valor, sensibilidade, criticidade e impacto em caso de divulgação, alteração, perda ou uso indevido. A classificação da informação orienta os controles de acesso, o armazenamento, o compartilhamento, a retenção e o descarte adequado dos dados, garantindo conformidade com a LGPD, normas do Banco Central, sigilo bancário e demais diretrizes de segurança da informação.

As informações da cooperativa são classificadas nos seguintes níveis:

- **Pública:** informações que podem ser divulgadas externamente sem causar prejuízo à BluCoop, aos cooperados, colaboradores ou parceiros. Incluem comunicados institucionais, materiais de divulgação e informações publicadas em canais oficiais;
- **Interna:** informações destinadas ao uso interno da cooperativa, que não devem ser divulgadas ao público externo sem autorização. Incluem comunicados internos, procedimentos administrativos, orientações operacionais e documentos de rotina;
- **Restrita:** informações cujo acesso deve ser limitado a áreas, funções ou pessoas autorizadas. Sua divulgação ou alteração indevida pode gerar impactos operacionais, financeiros, jurídicos, regulatórios ou reputacionais. Incluem relatórios internos, contratos, documentos de auditoria, registros de incidentes e informações de fornecedores;
- **Confidencial:** informações de alta sensibilidade, cujo acesso, uso ou divulgação indevida pode causar prejuízos graves à cooperativa, aos cooperados ou a terceiros. Incluem dados pessoais, dados financeiros, informações protegidas por sigilo bancário, credenciais de acesso, informações estratégicas e documentos sujeitos a obrigações legais específicas.

A classificação deve ser aplicada a todas as informações criadas, recebidas, armazenadas, transmitidas ou descartadas pela BluCoop, considerando todo o seu ciclo de vida. O acesso às informações deve seguir o princípio do menor privilégio, garantindo que cada usuário tenha acesso apenas aos dados necessários para o desempenho de suas atividades.

Informações restritas e confidenciais devem receber controles adicionais de proteção, como limitação de acesso, registro de uso, armazenamento seguro e compartilhamento apenas mediante autorização adequada. O envio dessas informações a terceiros somente poderá ocorrer quando houver finalidade legítima, obrigação contratual ou exigência legal, sempre observando as responsabilidades de confidencialidade e proteção dos dados.

Todos os colaboradores, prestadores de serviço e parceiros que tenham acesso às informações da BluCoop são responsáveis por respeitar a classificação atribuída e por comunicar imediatamente qualquer suspeita de uso indevido, acesso não autorizado, perda, vazamento ou exposição de informações.

4 GERENCIAMENTO DE ACESSO

O gerenciamento de acesso regula formalmente como as permissões são concedidas, monitoradas, modificadas e revogadas dentro da cooperativa, em conformidade com os controles estabelecidos pela ISO/IEC 27002 [5] e com os requisitos da Resolução CMN nº 4.893/2021 [2].

4.1 Controle de Acesso

A BluCoop deve centralizar o gerenciamento de identidades e permissões em um serviço de diretório corporativo. Nenhuma estação de trabalho ou sistema corporativo pode ser acessado sem uma conta devidamente registrada e autorizada. A estrutura de controle deve ser organizada em grupos que reflitam os departamentos da cooperativa, como TI, Atendimento, Financeiro, Suporte e Diretoria, possibilitando a aplicação de políticas e permissões de forma granular e alinhada ao perfil funcional de cada colaborador.

Complementarmente, a rede corporativa da matriz é segmentada por switches de distribuição dedicados a agrupamentos funcionais, de modo que colaboradores de uma área operacional não possuem acesso de rede às sub-redes pertencentes a outros departamentos. As atribuições de acesso são sempre individuais e nominais, reforçando a rastreabilidade de todas as ações realizadas nos sistemas da cooperativa, conforme recomendado pela ISO/IEC 27001 [4].

4.2 Autenticação

Todo acesso a computadores corporativos, sistemas internos e serviços integrados da BluCoop depende da validação de credenciais únicas geridas de forma centralizada. Colaboradores em regime remoto devem autenticar-se previamente por meio de solução de acesso seguro para estabelecer comunicação com a rede interna da cooperativa, sendo vedado o acesso direto aos servidores e sistemas corporativos por redes externas sem esse controle.

Nos ambientes em nuvem, o acesso administrativo aos servidores deve ser realizado por mecanismos de autenticação forte, eliminando o uso de senhas simples em ambientes de alta criticidade. O repositório central de dados deve exigir credenciais válidas em toda tentativa de conexão, garantindo que os dados dos cooperados sejam protegidos em conformidade com as exigências da LGPD [3].

4.3 Autorização

A autorização na BluCoop segue o princípio do menor privilégio, implementado por meio de grupos de segurança departamentais que refletem as áreas da cooperativa, como TI, Atendimento, Financeiro, Suporte e Diretoria. As políticas associadas a cada grupo definem restrições e configurações específicas por perfil, garantindo que colaboradores operem dentro dos limites compatíveis com suas atribuições sem possibilidade de escalada de privilégios não autorizada, conforme preconizado pela ISO/IEC 27002 [5].

O controle de autorização é reforçado na camada de rede por controles que restringem o tráfego de cada servidor exclusivamente aos serviços necessários para sua função. Qualquer alteração de função, desligamento ou movimentação de colaboradores deve ser imediatamente comunicada à equipe de TI para revisão e revogação das permissões associadas, assegurando que acessos obsoletos não permaneçam ativos na infraestrutura da cooperativa.

5 SEGURANÇA FÍSICA E AMBIENTAL

A segurança física e ambiental abrange a proteção dos ambientes, equipamentos e instalações utilizados para processar, armazenar e transmitir informações. A BluCoop opera em um modelo híbrido, com parte da infraestrutura hospedada em nuvem e parte sustentada por servidores físicos localizados em escritório central. Além disso, os colaboradores atuam em regime de trabalho remoto, acessando os sistemas corporativos a partir de seus domicílios por meio de equipamentos fornecidos pela cooperativa. Esse cenário distribui as responsabilidades físicas entre três ambientes distintos: o escritório central com servidores físicos, o ambiente de nuvem gerenciado pelo provedor contratado e os ambientes domésticos dos colaboradores.

A ISO/IEC 27001:2022 estabelece que a organização deve implementar controles físicos e ambientais para proteger as instalações de processamento de informações contra ameaças físicas e ambientais deliberadas ou acidentais [4]. A ABNT NBR ISO/IEC 27002:2022, em sua Seção 7, detalha os controles físicos aplicáveis a diferentes modelos de operação, incluindo ambientes híbridos e trabalho remoto [5]. Este capítulo define as diretrizes de segurança física para cada um dos ambientes em que a BluCoop opera.

5.1 Modelo de Responsabilidade Compartilhada

Ambientes e responsabilidades

O modelo híbrido da BluCoop distribui responsabilidades físicas conforme o ambiente. No ambiente de nuvem, a segurança física dos datacenters, incluindo controle de acesso às instalações, proteção contra incêndio, controle de temperatura e umidade, fornecimento redundante de energia e proteção contra desastres, é incumbência do provedor de nuvem contratado. No escritório central, onde estão alocados os servidores físicos, a BluCoop é integralmente responsável pelos controles físicos e ambientais. Nos ambientes domésticos dos colaboradores, a responsabilidade é compartilhada: a cooperativa deve estabelecer diretrizes claras e os colaboradores devem segui-las no uso dos equipamentos corporativos.

A Resolução CMN n.º 4.893/2021 exige que os serviços de processamento e armazenamento de dados contratados por instituições financeiras atendam aos mesmos padrões de segurança exigidos da própria instituição, incluindo a possibilidade de realização de auditorias e o fornecimento de relatórios de conformidade pelo provedor [2]. A BluCoop

deve verificar, no momento da contratação e periodicamente, se o provedor de nuvem mantém certificações atualizadas de segurança física, como ISO/IEC 27001 e SOC 2 Tipo II.

5.2 Segurança do Escritório Central e Servidores Físicos

Controle de acesso físico

O escritório central, por abrigar servidores físicos e equipamentos de infraestrutura crítica, deve contar com controles de acesso físico adequados ao nível de risco. O acesso às áreas onde estão instalados os servidores deve ser restrito a pessoal autorizado, com registro de entradas e saídas. Mecanismos de controle podem incluir crachás de identificação, cartões de proximidade, biometria ou combinação de fatores, conforme avaliação de risco da cooperativa. Visitantes e prestadores de serviço devem ser identificados, registrados e acompanhados por colaborador autorizado durante toda a permanência nas áreas restritas.

O NIST SP 800-53 recomenda que as organizações implementem mecanismos de controle de acesso físico às instalações, mantenham registros de acesso e revisem periodicamente as autorizações concedidas, revogando imediatamente os acessos de pessoas desligadas ou que mudaram de função [6].

Proteção dos servidores e equipamentos

Os servidores físicos e equipamentos de infraestrutura do escritório central devem ser instalados em local protegido, preferencialmente em rack fechado com travamento, com organização adequada de cabos e separação de circuitos elétricos. O ambiente deve contar com controle de temperatura e umidade compatível com as especificações dos equipamentos instalados, sistema de detecção de incêndio e proteção elétrica por meio de nobreaks e dispositivos contra surtos de tensão.

Manutenções e intervenções nos servidores devem ser realizadas apenas por pessoal autorizado, com registro de todas as atividades realizadas. Equipamentos que serão descartados ou reutilizados devem ter os dados removidos de forma segura, conforme os métodos de sanitização recomendados pelo NIST SP 800-88, que incluem limpeza lógica, purga ou destruição física, escolhidos de acordo com a sensibilidade das informações armazenadas [7].

Monitoramento do ambiente

O escritório central deve contar com monitoramento físico proporcional ao nível de criticidade dos ativos instalados. Câmeras de segurança nas entradas e em áreas de acesso aos

servidores, alarmes de intrusão e monitoramento de temperatura são medidas recomendadas. Os registros de monitoramento devem ser armazenados por período compatível com as exigências regulatórias e protegidos contra adulteração.

5.3 Segurança no Ambiente de Trabalho Remoto

Diretrizes para o home office

O trabalho remoto amplia o perímetro físico da cooperativa para os domicílios dos colaboradores, o que exige diretrizes específicas para proteção dos equipamentos e das informações acessadas fora do ambiente corporativo. A BluCoop deve estabelecer política de trabalho remoto que defina as responsabilidades dos colaboradores quanto à segurança física dos equipamentos fornecidos pela cooperativa, ao uso adequado desses equipamentos e à proteção do ambiente de trabalho doméstico.

A ABNT NBR ISO/IEC 27002:2022 orienta que as organizações devem implementar controles para proteger as informações acessadas, processadas ou armazenadas em locais de trabalho remoto, considerando os riscos físicos e ambientais do ambiente doméstico [5]. O acesso aos sistemas corporativos deve ser realizado exclusivamente por meio de VPN, garantindo a criptografia do tráfego entre o dispositivo do colaborador e a infraestrutura da BluCoop.

Proteção dos equipamentos corporativos

Os equipamentos fornecidos pela BluCoop aos colaboradores remotos, computadores, notebooks e demais dispositivos, devem ser utilizados exclusivamente para fins corporativos, conforme política de uso aceitável da cooperativa. Os colaboradores devem manter os equipamentos em local seguro, protegido contra acesso de terceiros não autorizados, incluindo familiares. Em caso de perda, roubo ou dano ao equipamento, o incidente deve ser comunicado imediatamente à equipe de TI para adoção das medidas cabíveis, como bloqueio remoto e revogação de acessos.

Notebooks e dispositivos móveis corporativos devem utilizar criptografia de disco completo para proteger as informações armazenadas localmente em caso de perda ou roubo. Senhas de acesso ao sistema operacional são obrigatórias e devem seguir os requisitos de complexidade definidos na política de controle de acesso da BluCoop.

5.4 Política de Mesa Limpa e Tela Limpa

Mesa limpa

A política de mesa limpa aplica-se tanto ao escritório central quanto aos ambientes de trabalho remoto. Documentos físicos contendo informações confidenciais, como dados de cooperados, contratos e documentos financeiros, não devem ser deixados sobre mesas ou áreas de trabalho sem supervisão. Ao término do expediente ou ao se ausentar do posto de trabalho, o colaborador deve guardar os documentos sensíveis em local seguro e com acesso restrito.

Tela limpa

Os dispositivos corporativos devem ser configurados para bloquear a tela automaticamente após período de inatividade não superior a cinco minutos. Os colaboradores devem bloquear manualmente as telas ao se afastarem do equipamento, mesmo que por curto período. No ambiente doméstico, essa medida é especialmente importante para evitar que informações corporativas sejam visualizadas por pessoas não autorizadas presentes no mesmo ambiente.

5.5 Descarte Seguro de Documentos e Dispositivos

Documentos físicos contendo informações confidenciais devem ser descartados por meio de fragmentadoras de papel ou serviço terceirizado de destruição segura, vedado o descarte em lixo comum. No ambiente de trabalho remoto, os colaboradores devem seguir os procedimentos definidos pela cooperativa para descarte de documentos, podendo ser orientados a encaminhar os documentos ao escritório central para destruição adequada.

Dispositivos corporativos que serão descartados, reutilizados ou devolvidos devem ter todos os dados removidos de forma segura antes da destinação final, utilizando os métodos de sanitização recomendados pelo NIST SP 800-88 [7]. A equipe de TI é responsável por realizar ou supervisionar o processo de sanitização e por manter registro das destinações realizadas.

6 SEGURANÇA DE REDES E COMUNICAÇÕES

A segurança das redes e comunicações é essencial para garantir a proteção das informações que trafegam pela infraestrutura da BluCoop. A cooperativa opera uma rede composta por matriz e cinco filiais interligadas à sede, além de acesso remoto de colaboradores, serviços corporativos críticos e comunicação com sistemas externos. Esse ambiente exige controles robustos para prevenir interceptações, acessos não autorizados, interrupções de serviço e vazamentos de dados.

A ISO/IEC 27001:2022 estabelece que a organização deve gerenciar e controlar as redes para proteger as informações nos sistemas e nas aplicações, aplicando controles para assegurar a segurança das informações nas redes e proteger os serviços de rede contra acessos não autorizados [4]. Este capítulo define as diretrizes para proteção da rede corporativa, segmentação, monitoramento, acesso remoto seguro, proteção de comunicações e gestão de equipamentos de rede.

6.1 Arquitetura e Segmentação de Rede

Princípios de arquitetura segura

A arquitetura de rede da BluCoop deve ser projetada com base nos princípios de defesa em profundidade, menor privilégio e segmentação. O NIST SP 800-41 orienta que as organizações devem implementar firewalls e controles de acesso à rede para segmentar e proteger os ambientes, definindo políticas que restrinjam o tráfego ao mínimo necessário para as operações [8]. A rede corporativa deve ser organizada em zonas distintas, com controles de acesso entre elas.

A arquitetura deve contemplar, no mínimo, a separação entre zonas distintas de rede: a zona de servidores críticos, a zona de usuários internos, a zona destinada a serviços expostos à internet, a zona de acesso remoto e a zona das filiais. A comunicação entre zonas deve ser mediada por controles de segurança e regida por regras explícitas e documentadas.

Segmentação de rede

A segmentação de rede deve isolar diferentes grupos de usuários, sistemas e serviços, limitando o acesso ao estritamente necessário. Servidores que armazenam ou processam dados críticos devem estar em segmentos separados, com acesso restrito apenas aos sistemas e usuários que deles necessitam. Os serviços de comunicação por voz devem operar em segmento próprio, de modo a garantir qualidade e segurança das comunicações.

As filiais devem ter suas redes locais segmentadas de forma similar, com isolamento entre áreas de atendimento ao cooperado e sistemas administrativos. O tráfego entre a matriz e as filiais deve ocorrer exclusivamente por canais de comunicação protegidos, sem acesso direto entre filiais que não seja mediado pela infraestrutura central. A ABNT NBR ISO/IEC 27002:2022, em sua Seção 8, estabelece diretrizes específicas para segmentação de redes, filtragem de tráfego e proteção de serviços de rede [5].

6.2 Firewalls e Controle de Tráfego

Implantação e configuração de firewalls

Firewalls devem ser implantados nos pontos de entrada e saída da rede da matriz e em cada filial, controlando o tráfego de rede com base em políticas definidas e aprovadas pela equipe de segurança da informação. As regras de firewall devem seguir o princípio do menor privilégio, permitindo apenas o tráfego estritamente necessário para as operações e bloqueando todo o restante por padrão (política de negar tudo, exceto o explicitamente permitido).

O NIST SP 800-41 recomenda que as políticas de firewall sejam documentadas, revisadas periodicamente e que as regras obsoletas ou desnecessárias sejam removidas para reduzir a superfície de ataque [8]. A BluCoop deve manter inventário atualizado das regras de firewall, com justificativa de negócio para cada regra existente.

Sistemas de detecção e prevenção de intrusão

Sistemas de detecção de intrusão (IDS) e prevenção de intrusão (IPS) devem ser implantados para monitorar o tráfego de rede em busca de padrões anômalos e ameaças conhecidas. Esses sistemas devem cobrir os pontos críticos da rede, incluindo as interfaces de comunicação com a internet e os acessos aos servidores que armazenam dados sensíveis. Alertas gerados pelos sistemas devem ser integrados ao processo de resposta a incidentes, com notificação imediata da equipe de segurança.

As assinaturas e regras dos sistemas de detecção devem ser atualizadas regularmente para cobrir novas ameaças e vulnerabilidades. A equipe de TI deve revisar os alertas periodicamente e ajustar as configurações para reduzir falsos positivos e garantir eficácia na detecção de ameaças reais.

6.3 Proteção das Comunicações entre Unidades e Acesso Externo

Segurança das comunicações entre unidades

Os canais de comunicação que interligam a matriz às filiais devem ser contratados com provedores que ofereçam garantias de disponibilidade, latência e segurança. Todo o tráfego transmitido entre as unidades deve ser criptografado para proteger as informações contra interceptação. A BluCoop deve adotar mecanismos que assegurem a confidencialidade e a integridade das comunicações entre as unidades.

Devem ser estabelecidos acordos de nível de serviço (SLA) com os provedores de conectividade, definindo disponibilidade mínima, tempo de resposta para incidentes e procedimentos de escalção. A política deve prever alternativas de contingência para as filiais mais críticas, garantindo continuidade operacional em caso de falha da conexão principal.

VPN para acesso remoto

O acesso remoto à rede da BluCoop deve ser realizado exclusivamente por meio de VPN (Virtual Private Network), utilizando protocolos seguros e autenticação multifator. A VPN garante que os dados transmitidos entre o dispositivo do usuário remoto e a rede corporativa sejam criptografados, protegendo as informações contra interceptação em redes públicas ou não confiáveis.

O NIST SP 800-113 orienta que as organizações devem implementar soluções de acesso remoto seguro que incluam autenticação forte, criptografia do tráfego e monitoramento das sessões remotas [9]. A BluCoop deve adotar autenticação de dois fatores para todos os acessos VPN, combinando senha com token, certificado digital ou aplicativo de autenticação. Perfis de acesso remoto devem ser individuais e revisados periodicamente, com revogação imediata em caso de desligamento ou mudança de função do colaborador.

Proteção dos serviços críticos de rede

Os serviços de resolução de nomes e demais serviços críticos de rede da matriz são ativos que, se comprometidos, podem afetar toda a operação das filiais. A BluCoop deve implementar controles específicos para proteger esses serviços, incluindo o monitoramento de atividades anômalas e o registro de eventos para fins de auditoria.

Ataques direcionados aos serviços críticos de rede, incluindo tentativas de falsificação de registros e ataques de negação de serviço (DDoS), devem ser considerados no modelo de ameaças da cooperativa. Medidas de mitigação, como redundância e replicação dos serviços essenciais, devem ser avaliadas e implementadas conforme o perfil de risco identificado.

6.4 Proteção de Comunicações e Protocolos Seguros

Criptografia em trânsito

Toda comunicação que envolva transmissão de dados sensíveis deve ser protegida por criptografia em trânsito. Os serviços e aplicações internos e externos devem utilizar protocolos de comunicação seguros e atualizados, evitando versões obsoletas e mecanismos de criptografia considerados fracos. A transferência de arquivos deve ser realizada por meio de canais que adicionem proteção criptográfica ao processo.

A comunicação entre as filiais e a matriz, incluindo acesso a sistemas, repositórios de dados e serviços internos, deve ocorrer exclusivamente por canais criptografados. A política deve proibir o uso de protocolos de comunicação não criptografados para transmissão de informações sensíveis.

Segurança das comunicações de voz

O sistema de comunicação por voz da BluCoop deve contar com controles de segurança específicos. Esse serviço deve operar de forma segregada, com acesso restrito aos dispositivos autorizados, autenticação obrigatória e substituição de credenciais padrão. O tráfego de sinalização e de voz deve ser protegido por criptografia.

Ameaças específicas às comunicações de voz, como interceptação de chamadas, fraude tarifária e ataques de negação de serviço, devem ser contempladas no modelo de ameaças da cooperativa. Registros de chamadas devem ser mantidos para fins de auditoria e investigação de incidentes.

6.5 Monitoramento e Registro de Rede

Logs e registros de rede

A BluCoop deve implementar coleta e armazenamento centralizado de logs de todos os dispositivos de rede, incluindo firewalls, switches, roteadores, servidores VPN e sistemas de detecção de intrusão. Os registros devem conter informações suficientes para reconstrução de eventos, incluindo data, hora, endereços de origem e destino, protocolos utilizados e ações realizadas. A integridade dos logs deve ser protegida contra alteração ou exclusão não autorizada.

O NIST SP 800-92 orienta que as organizações devem estabelecer políticas de gestão de logs, definindo quais eventos devem ser registrados, por quanto tempo os registros devem ser retidos e como devem ser protegidos [10]. A BluCoop deve definir período mínimo de

retenção de logs compatível com as exigências regulatórias do Bacen, que determina a manutenção de documentação por pelo menos cinco anos [2].

Monitoramento contínuo da rede

O monitoramento contínuo da rede deve ser implementado para detecção em tempo real de anomalias, tentativas de intrusão e comportamentos suspeitos. Ferramentas de SIEM (Security Information and Event Management) podem ser utilizadas para correlacionar eventos de diferentes fontes e gerar alertas automatizados. O monitoramento deve abranger o tráfego entre todas as zonas de rede, acessos VPN, comunicações WAN e acessos aos servidores críticos.

Os resultados do monitoramento devem ser revisados pela equipe de TI e segurança da informação, com procedimentos definidos para investigação e resposta a alertas. Indicadores de desempenho relacionados ao monitoramento, como tempo de detecção de incidentes e taxa de falsos positivos, devem ser acompanhados como parte do programa de métricas descrito na seção 8 deste documento.

6.6 Gestão de Equipamentos de Rede

Hardening de dispositivos de rede

Todos os equipamentos de rede, roteadores, switches, firewalls e access points, devem ser configurados conforme boas práticas de hardening. Isso inclui a alteração de senhas e credenciais padrão, desativação de serviços e interfaces não utilizados, atualização de firmware e remoção de configurações desnecessárias. As configurações de hardening devem ser documentadas e verificadas periodicamente por meio de auditorias de configuração.

O CIS (Center for Internet Security) publica benchmarks de configuração segura para os principais fabricantes e modelos de equipamentos de rede, que podem ser utilizados como referência pela equipe de TI da BluCoop [11]. A adoção de configurações baseadas nesses benchmarks reduz significativamente a superfície de ataque da infraestrutura de rede.

Gestão de mudanças na rede

Toda alteração na infraestrutura de rede, incluindo mudanças em regras de controle de tráfego, configurações de roteamento, implantação de novos equipamentos ou modificação de segmentos de rede, deve passar por processo formal de gestão de mudanças. As mudanças devem ser avaliadas, aprovadas e documentadas antes de sua implementação, com procedimentos de retorno à configuração anterior definidos para casos de falha.

A gestão de mudanças reduz o risco de erros de configuração que possam criar vulnerabilidades ou interromper serviços. Registros de todas as mudanças realizadas na rede devem ser mantidos para fins de auditoria e diagnóstico de incidentes.

A implementação dos controles de segurança de redes e comunicações aqui descritos, combinada com os controles físicos e ambientais do tópico 4, estabelece uma base sólida de proteção para a infraestrutura da BluCoop. A eficácia desses controles deve ser avaliada periodicamente por meio das auditorias e métricas definidas nos tópicos subsequentes da Política de Segurança da Informação.

7 GESTÃO DE INCIDENTES DE SEGURANÇA

A gestão de incidentes de segurança da informação é um dos pilares operacionais da Política de Segurança da BluCoop, pois traduz, em procedimentos práticos, a capacidade da cooperativa de identificar, conter e recuperar-se de eventos que comprometam a confidencialidade, a integridade ou a disponibilidade de suas informações. Considerando a infraestrutura apresentada na seção 5, na qual a matriz de Blumenau concentra os serviços corporativos críticos e na qual cinco filiais se conectam à sede e colaboradores remotos acessam a rede de forma segura, qualquer incidente possui potencial de afetar simultaneamente diversas unidades. Por esse motivo, a cooperativa deve manter um processo estruturado de resposta a incidentes, capaz de atuar de forma rápida e coordenada.

Esta seção define o processo completo adotado pela BluCoop, abrangendo a identificação, o registro, a classificação, a resposta, a contenção, a erradicação, a recuperação e a documentação dos incidentes. O processo está alinhado às boas práticas internacionais e às exigências regulatórias aplicáveis às instituições financeiras, em especial a obrigação, prevista na regulamentação do Banco Central, de manter plano de ação e resposta a incidentes aprovado pela alta administração [1][2].

7.1 Processo de Gestão de Incidentes

7.1.1 Identificação

A identificação consiste na detecção de eventos que possam representar uma ameaça à segurança da informação. Na BluCoop, a identificação ocorre por meio de múltiplas fontes: alertas gerados pelas ferramentas de monitoramento implantadas sobre os servidores da matriz e das filiais, com regras configuradas para serviços críticos, registros de acesso e autenticação, registros dos dispositivos de segurança de rede, além de comunicações realizadas pelos próprios colaboradores. Cabe destacar que o monitoramento contínuo descrito na seção 5 desempenha papel central nessa fase, uma vez que a detecção automática de indisponibilidade e de comportamentos anômalos reduz o tempo entre a ocorrência e a percepção do incidente.

7.1.2 Registro

Todo evento identificado deve ser formalmente registrado em um sistema de controle de chamados, garantindo rastreabilidade desde o primeiro momento. O registro deve conter, no mínimo: data e hora da detecção, fonte da informação, descrição do evento, ativos potencialmente afetados, responsável pelo registro e classificação inicial de criticidade. O registro estruturado é essencial para atender ao requisito regulatório de rastreabilidade e de

registro de incidentes e para subsidiar o posterior relatório anual exigido pelo Banco Central [1].

7.1.3 Classificação

Após o registro, o incidente deve ser classificado quanto ao seu tipo (por exemplo, malware, phishing, acesso não autorizado, indisponibilidade de serviço ou vazamento de dados) e quanto ao seu nível de criticidade. A classificação determina a prioridade de tratamento, os recursos a serem mobilizados e os prazos de resposta, conforme detalhado na seção 6.4. A correta classificação evita tanto a subestimação de incidentes graves quanto o consumo desnecessário de recursos com eventos de baixo impacto.

7.1.4 Resposta

A resposta corresponde ao conjunto de ações imediatas executadas para tratar o incidente após sua classificação. Nessa fase, a equipe responsável avalia a extensão do problema, mobiliza os profissionais adequados e decide a estratégia de tratamento. A resposta deve seguir o fluxo definido na seção 6.2 e considerar a organização da rede: por exemplo, um incidente restrito a uma filial pode ser tratado isolando-se a unidade afetada, ao passo que um incidente na matriz exige acionamento mais amplo, dada a centralização dos serviços críticos.

7.1.5 Contenção

A contenção visa limitar a propagação do incidente e reduzir seus impactos. As medidas de contenção variam conforme o caso e podem incluir: isolamento de estações de trabalho comprometidas, bloqueio de contas de usuário, suspensão de acessos remotos, segregação de uma filial em relação à rede central, bloqueio de tráfego suspeito ou desativação temporária de um serviço afetado. A segmentação de rede e a separação entre a rede corporativa e a rede pública, já previstas na infraestrutura descrita na seção 5, favorecem a contenção, pois limitam a superfície de propagação de uma ameaça.

7.1.6 Erradicação

A erradicação consiste na remoção definitiva da causa do incidente. Isso pode envolver a eliminação de artefatos maliciosos, a correção de vulnerabilidades exploradas, a aplicação de patches, a redefinição de credenciais comprometidas e a revisão de configurações inadequadas. Em casos de comprometimento profundo de um servidor ou estação, pode ser necessária a reinstalação completa do sistema operacional a partir de imagem confiável, assegurando que nenhum vestígio da ameaça permaneça no ambiente.

7.1.7 Recuperação

A recuperação tem por objetivo restabelecer os serviços afetados às condições normais de operação de forma segura. Nessa etapa, os sistemas são restaurados, preferencialmente a partir de backups íntegros, e submetidos a verificações antes de retornarem à produção. O plano de recuperação específico da BluCoop é detalhado na seção 6.7. Durante a recuperação, é fundamental monitorar de perto os ativos restaurados para confirmar que o incidente foi efetivamente eliminado e que não há reincidência.

7.1.8 Documentação

Ao final, todo o ciclo do incidente deve ser documentado em um relatório formal, contendo a cronologia dos fatos, as ações executadas, os responsáveis envolvidos, os impactos observados, as evidências coletadas e as recomendações de melhoria. Essa documentação alimenta o processo de lições aprendidas (seção 6.8), serve de base para auditorias e atende às exigências de registro e de comunicação previstas na legislação aplicável, incluindo a eventual notificação à Autoridade Nacional de Proteção de Dados (ANPD) e aos titulares, quando o incidente envolver dados pessoais [3].

7.2 Fluxo de Resposta a Incidentes

O fluxo de resposta a incidentes da BluCoop organiza, em etapas sequenciais e bem definidas, as ações que devem ser executadas desde a detecção até o encerramento do incidente. O fluxo padrão é o seguinte:

- **Detecção e registro:** o evento é identificado por uma das fontes de monitoramento ou comunicado por um colaborador e imediatamente registrado no sistema de chamados.
- **Triagem e classificação:** a equipe de segurança avalia o registro, confirma se há de fato um incidente e atribui o tipo e o nível de criticidade.
- **Acionamento:** conforme a criticidade, os papéis e responsáveis definidos na seção 6.3 são acionados pelos canais de comunicação adequados.
- **Contenção:** são aplicadas as medidas para impedir a propagação, isolando ativos, contas ou segmentos de rede afetados.
- **Erradicação:** a causa-raiz é removida e as vulnerabilidades exploradas são corrigidas.
- **Recuperação:** os serviços são restaurados de forma segura e monitorados quanto à estabilidade.

- **Encerramento e documentação:** o incidente é formalmente fechado, documentado e encaminhado para análise de lições aprendidas.

Esse fluxo deve ser tratado como um ciclo, e não como uma sequência rígida: caso a recuperação revele que a erradicação foi incompleta, o processo retorna às etapas anteriores até a resolução definitiva do incidente.

7.3 Papéis e Responsabilidades

A eficácia da resposta a incidentes depende da definição clara de papéis e responsabilidades. Na estrutura da BluCoop, descrita na seção 5, as atribuições são distribuídas da seguinte forma:

- **Alta administração (Conselho Executivo e Diretoria de Tecnologia):** responsável por aprovar a política e o plano de resposta a incidentes, por designar formalmente o responsável pela segurança cibernética e por decidir sobre comunicações externas em incidentes de alta criticidade.
- **Equipe de Tecnologia da Informação da matriz:** atua como núcleo da resposta, conduzindo as ações técnicas de contenção, erradicação e recuperação sobre os servidores centrais, os controles de rede, o serviço de diretório e as comunicações entre as unidades.
- **Suporte de TI das filiais:** executa, localmente, as ações de primeira resposta orientadas pela equipe da matriz, como isolamento de estações e verificações iniciais, encaminhando as demandas complexas à matriz.
- **Encarregado pelo tratamento de dados pessoais (DPO):** avalia os incidentes que envolvam dados pessoais e conduz as eventuais comunicações à ANPD e aos titulares, em conformidade com a LGPD [3].
- **Colaboradores em geral:** têm a responsabilidade de comunicar imediatamente qualquer evento suspeito, conforme as orientações de conscientização tratadas na seção 7.

7.4 Níveis de Criticidade

Os incidentes são classificados em quatro níveis de criticidade, que determinam a prioridade, os prazos de resposta e os recursos mobilizados. O quadro a seguir resume essa classificação contextualizada para a infraestrutura da BluCoop:

Quadro 1 - Níveis de criticidade de incidentes da BluCoop

Nível	Classificação	Descrição / Exemplos na BluCoop	Tempo-alvo de resposta
1	Crítico	Indisponibilidade do repositório central de dados, ataque de ransomware, comprometimento dos serviços de comunicação ou interrupção total da conectividade entre as unidades.	Acionamento imediato (até 1h); resposta 24x7.
2	Alto	Comprometimento de servidor de filial, infecção por malware, falha de serviço corporativo relevante ou indisponibilidade do acesso remoto.	Resposta em até 4 horas úteis.
3	Médio	Tentativas de phishing, tentativas de varredura da rede, indisponibilidade pontual de serviço não crítico.	Resposta em até 1 dia útil.
4	Baixo	Violações leves de política de uso, instalação de software não autorizado, bloqueios de conta por erro de senha.	Resposta em até 3 dias úteis.

Fonte: Elaborado pelos próprios autores.

A definição prévia desses níveis permite que a equipe responda de maneira proporcional ao risco, priorizando incidentes que afetem os ativos mais sensíveis, como o banco de dados central de cooperados, e evitando a mobilização desnecessária de recursos em eventos de baixo impacto.

7.5 Canais de Comunicação

A comunicação durante um incidente deve ser ágil, controlada e registrada. A BluCoop deve manter canais formais e previamente definidos para o acionamento da equipe e para a disseminação de informações. Internamente, recomenda-se a utilização de múltiplos meios complementares, tais como notificações por e-mail corporativo, mensagens em grupos dedicados e contatos telefônicos diretos para os incidentes críticos, garantindo redundância caso um dos canais esteja indisponível.

Externamente, a comunicação deve obedecer a critérios bem definidos. Incidentes relevantes devem ser comunicados ao Banco Central e, quando envolverem dados pessoais com risco aos titulares, à ANPD, sempre por meio dos responsáveis formalmente designados [1][3]. É vedado a colaboradores não autorizados prestar informações sobre incidentes a terceiros, à imprensa ou a redes sociais, preservando o sigilo bancário e a reputação da cooperativa.

7.6 Registro de Evidências

O registro adequado de evidências é indispensável tanto para a investigação técnica quanto para o eventual atendimento a requisições legais e auditorias. Durante o tratamento do incidente, a equipe deve preservar logs de sistemas, registros dos dispositivos de segurança e do serviço de diretório, capturas de tela, cópias de arquivos suspeitos e quaisquer artefatos relacionados, evitando alterações que comprometam sua integridade.

As evidências devem ser armazenadas de forma íntegra e com controle de acesso restrito, em repositórios dedicados e protegidos por criptografia em repouso. Recomenda-se manter o registro da cadeia de custódia, isto é, do histórico de quem acessou e manipulou cada evidência. Em conformidade com a regulamentação do Banco Central, a documentação relacionada a incidentes deve ser mantida por período não inferior a cinco anos [1].

7.7 Plano de Recuperação

O plano de recuperação define como a BluCoop restabelece a continuidade de suas operações após um incidente, com ênfase nos serviços críticos centralizados na matriz. O plano apoia-se na infraestrutura de backup e replicação já prevista no projeto e estabelece prioridades de restauração baseadas na criticidade dos ativos.

As diretrizes do plano de recuperação incluem:

- **Priorização de serviços:** os serviços corporativos críticos hospedados na matriz, responsáveis por sustentar a operação de todas as unidades, têm prioridade máxima de restauração.
- **Restauração a partir de backups:** os serviços devem ser restaurados a partir de cópias de segurança íntegras e previamente testadas, evitando a reintrodução de artefatos maliciosos no ambiente.
- **Verificação pós-recuperação:** antes do retorno à produção, os sistemas restaurados devem ser validados e monitorados pelas ferramentas de monitoramento da cooperativa, confirmando a estabilidade e a ausência de reincidência.
- **Comunicação às filiais:** uma vez restabelecidos os serviços centrais, as filiais devem ser informadas e ter sua conectividade com a matriz validada.
- **Cenários de continuidade:** o plano deve contemplar cenários de ataques cibernéticos, indisponibilidade de links e falhas de servidores, em linha com a exigência regulatória de planos de continuidade de negócios [2].

7.8 Lições Aprendidas

Após o encerramento de cada incidente relevante, a BluCoop deve conduzir uma análise de lições aprendidas, com o objetivo de transformar a experiência em melhoria contínua. Essa análise reúne os responsáveis envolvidos para revisar a cronologia do incidente, avaliar a eficácia das ações adotadas, identificar falhas de processo ou de controle e propor medidas corretivas e preventivas.

Os resultados dessa análise devem realimentar a política de segurança, a análise de riscos, os controles técnicos e os programas de treinamento, conectando-se diretamente ao ciclo de avaliação e melhoria contínua descrito na seção 8. Dessa forma, cada incidente contribui para fortalecer a postura de segurança da cooperativa e reduzir a probabilidade de recorrência.

7.9 Relação com a Infraestrutura de Rede

A gestão de incidentes proposta está diretamente ancorada na infraestrutura apresentada na seção 5. A organização da rede, com a matriz de Blumenau como ponto central, define a forma como os incidentes se propagam e são contidos: eventos em filiais podem ser isolados localmente, enquanto eventos na matriz exigem resposta ampliada pela centralização dos serviços críticos.

Da mesma forma, a separação entre rede corporativa e rede pública, a autenticação centralizada de usuários, o controle de tráfego de rede, o acesso remoto seguro e o monitoramento contínuo constituem os instrumentos práticos de detecção, contenção e recuperação descritos nesta seção. Assim, a gestão de incidentes não é um processo isolado, mas a aplicação operacional dos recursos tecnológicos já implantados, garantindo coerência entre a arquitetura de rede e os procedimentos de segurança.

8 CONSCIENTIZAÇÃO E TREINAMENTO EM SEGURANÇA

A tecnologia, por si só, não é suficiente para garantir a segurança da informação. Grande parte dos incidentes de segurança tem origem em fatores humanos, como o uso inadequado de credenciais, a abertura de mensagens fraudulentas ou a queda em golpes de engenharia social. Por essa razão, a BluCoop deve manter um programa permanente de conscientização e treinamento, voltado a reduzir os riscos humanos e a transformar seus colaboradores na primeira linha de defesa da cooperativa.

Esta seção define como a cooperativa deve capacitar seus colaboradores, abrangendo treinamentos periódicos, campanhas de conscientização, boas práticas no uso dos recursos corporativos, prevenção contra phishing e engenharia social, orientações para uso seguro da rede, responsabilidades dos usuários e mecanismos de avaliação de aprendizagem. O programa complementa diretamente os mecanismos de segurança definidos na seção 8, conferindo-lhes efetividade no dia a dia operacional.

8.1 Treinamentos Periódicos

A BluCoop deve oferecer treinamentos periódicos de segurança da informação a todos os colaboradores, com frequência mínima anual e sempre que houver mudanças relevantes em políticas, sistemas ou no cenário de ameaças. Os treinamentos devem abordar a Política de Segurança da Informação, os procedimentos de uso dos recursos corporativos, a forma correta de comunicar incidentes e as responsabilidades individuais de cada usuário.

Os conteúdos devem ser adaptados aos diferentes perfis de público. Colaboradores das áreas de Atendimento e Administrativa devem receber orientações focadas no tratamento de dados de cooperados e no atendimento seguro, enquanto a equipe de TI deve receber capacitação técnica mais aprofundada. Novos colaboradores devem passar por treinamento de integração antes de obterem acesso pleno aos sistemas. A cooperativa pode apoiar-se em seu Ambiente Virtual de Aprendizagem para disponibilizar os conteúdos de forma escalável e acessível a todas as unidades.

8.2 Campanhas de Conscientização

Além dos treinamentos formais, a BluCoop deve promover campanhas contínuas de conscientização, com o objetivo de manter a segurança presente no cotidiano dos colaboradores. Essas campanhas podem utilizar comunicados internos, cartazes nas unidades,

mensagens periódicas por e-mail e avisos no mural interno, abordando temas como senhas seguras, identificação de e-mails fraudulentos e cuidados com dispositivos.

Recomenda-se a realização de simulações controladas de phishing, nas quais mensagens fictícias são enviadas aos colaboradores para medir o nível de atenção da equipe e direcionar reforços de treinamento, sem caráter punitivo. As campanhas devem ser recorrentes e renovadas, evitando que a mensagem de segurança se torne repetitiva e perca eficácia.

8.3 Boas Práticas no Uso de Senhas, E-mail, Internet e Dispositivos

O programa de conscientização deve orientar os colaboradores quanto às boas práticas no uso dos recursos corporativos, em alinhamento com os controles técnicos definidos na seção 8:

- **Senhas:** utilizar senhas fortes e exclusivas, não compartilhá-las com terceiros, evitar anotá-las em locais visíveis e adotar a autenticação em duas etapas sempre que disponível. As políticas de senha aplicadas de forma centralizada reforçam tecnicamente essas orientações.
- **E-mail:** desconfiar de mensagens inesperadas, verificar remetentes, não abrir anexos ou links suspeitos e jamais fornecer credenciais ou dados sensíveis em resposta a e-mails.
- **Internet:** evitar o acesso a sites não confiáveis a partir de equipamentos corporativos, não realizar downloads de fontes desconhecidas e respeitar as políticas de navegação aplicadas pelo firewall de borda.
- **Dispositivos:** manter estações de trabalho bloqueadas quando ausentes, não instalar softwares não autorizados, utilizar apenas dispositivos removíveis aprovados e comunicar imediatamente a perda ou o furto de equipamentos.

8.4 Prevenção contra Phishing e Engenharia Social

O phishing e a engenharia social estão entre as principais ameaças enfrentadas pelas instituições financeiras, pois exploram a confiança e o desconhecimento das pessoas para obter acesso indevido a informações e sistemas. Os colaboradores da BluCoop devem ser treinados para reconhecer sinais de tentativas de fraude, como senso de urgência artificial, solicitações incomuns de transferência de informações, endereços de remetente falsificados e mensagens com erros ou links disfarçados.

A orientação central é a de que, diante de qualquer solicitação suspeita, o colaborador deve validar a autenticidade por canais oficiais e jamais fornecer credenciais, dados de cooperados ou informações sigilosas. Toda tentativa identificada deve ser comunicada à equipe de TI, integrando-se ao processo de gestão de incidentes descrito na seção 6, no qual o phishing é tratado como incidente de criticidade média passível de escalonamento.

8.5 Orientações para Uso Seguro da Rede Corporativa

Considerando a infraestrutura descrita na seção 5, os colaboradores devem ser orientados quanto ao uso seguro da rede corporativa. Deve-se reforçar a separação entre a rede corporativa interna e a rede pública (Wi-Fi) destinada a cooperados e visitantes, esclarecendo que dispositivos pessoais e atividades não relacionadas ao trabalho não devem utilizar a rede corporativa.

Para o trabalho remoto, predominante no modelo híbrido da matriz, os colaboradores devem utilizar exclusivamente a VPN para acessar os sistemas internos, evitar redes Wi-Fi públicas inseguras e assegurar que seus equipamentos estejam atualizados e protegidos. Essas orientações garantem que os mecanismos de segmentação e de acesso remoto seguro previstos no projeto sejam efetivamente respeitados pelos usuários.

8.6 Responsabilidades dos Usuários

Cada colaborador é corresponsável pela segurança da informação na BluCoop. Entre as principais responsabilidades dos usuários, destacam-se:

- Conhecer e cumprir a Política de Segurança da Informação e os procedimentos dela decorrentes.
- Proteger suas credenciais de acesso e utilizá-las apenas para as finalidades autorizadas.
- Utilizar os recursos corporativos de forma ética e profissional, respeitando o princípio do menor privilégio.
- Comunicar imediatamente à equipe de TI qualquer incidente, suspeita ou vulnerabilidade observada.
- Preservar o sigilo das informações dos cooperados, em conformidade com a LGPD e com a legislação de sigilo bancário.

O descumprimento dessas responsabilidades pode acarretar medidas administrativas, conforme previsto na política, reforçando a cultura de responsabilização compartilhada pela segurança.

8.7 Avaliação de Aprendizagem

Para assegurar que os treinamentos e campanhas produzam resultados efetivos, a BluCoop deve avaliar continuamente o aprendizado dos colaboradores. Essa avaliação pode ser realizada por meio de questionários aplicados ao término de cada treinamento, da análise dos resultados das simulações de phishing e do acompanhamento de indicadores como o percentual de colaboradores treinados e a taxa de reincidência em comportamentos de risco.

Os resultados dessas avaliações devem orientar o aprimoramento do próprio programa, identificando temas que demandam reforço e perfis que necessitam de atenção adicional. Esses indicadores integram-se às métricas de desempenho de segurança da informação descritas na seção 8, permitindo demonstrar à direção a evolução da maturidade da cooperativa e fundamentar decisões de investimento em capacitação.

8.8 Relação com os Mecanismos de Segurança

O programa de conscientização e treinamento não substitui, mas complementa e potencializa os mecanismos de segurança definidos nas seções anteriores. Controles como a gestão de vulnerabilidades e patches, a análise de riscos e as auditorias dependem, em última instância, do comportamento adequado dos usuários para alcançarem sua plena eficácia. De nada adianta, por exemplo, manter políticas rigorosas de senha se os colaboradores as compartilham ou anotam de forma insegura.

Da mesma forma, o monitoramento e a medição de desempenho ganham um componente humano essencial: o percentual de colaboradores treinados torna-se um indicador de maturidade tão relevante quanto o tempo de aplicação de patches ou o número de vulnerabilidades abertas. Assim, a conscientização e o treinamento fecham o ciclo da segurança da informação na BluCoop, integrando pessoas, processos e tecnologia em uma abordagem coerente e contínua.

9 AVALIAÇÃO E MELHORIA CONTÍNUA

A Política de Segurança da Informação da BluCoop deve evoluir conforme o ambiente tecnológico, as ameaças cibernéticas e as exigências legais e regulatórias aplicáveis. A cooperativa possui uma estrutura composta por matriz e cinco filiais interligadas à sede, além de colaboradores em acesso remoto, o que exige monitoramento constante, revisão periódica de controles e atualização contínua das práticas de segurança.

A matriz concentra os serviços corporativos críticos responsáveis por sustentar as operações das filiais. Por isso, a avaliação e a melhoria contínua devem garantir que os controles de segurança permaneçam adequados para proteger a confidencialidade, a integridade e a disponibilidade das informações.

9.1 Auditorias de Segurança

Programa de auditorias

A BluCoop deve realizar auditorias periódicas de segurança para avaliar a eficácia das políticas, procedimentos e controles adotados. As auditorias devem verificar se os controles estão implementados corretamente, se atendem aos requisitos legais e regulatórios e se são capazes de reduzir riscos de incidentes de segurança. Auditorias de segurança permitem identificar vulnerabilidades, falhas de configuração, descumprimento de políticas internas e oportunidades de melhoria.

Escopo das auditorias

As auditorias devem abranger os principais ativos e processos da cooperativa, incluindo servidores centrais, equipamentos de rede, estações de trabalho, sistemas internos, conexões de acesso remoto, comunicações entre as unidades, ambientes das filiais e serviços terceirizados. Também devem ser avaliados os controles de autenticação, autorização, segmentação de rede, backups, registros de acesso, proteção contra malware, resposta a incidentes e segurança física dos ambientes críticos.

Auditorias internas e externas

A BluCoop deve realizar auditorias internas semestrais, conduzidas pela equipe de segurança da informação ou por responsáveis designados pela área de TI. Além disso, recomenda-se a realização de auditorias externas anuais ou sempre que houver mudanças relevantes na infraestrutura, nos sistemas ou nas exigências regulatórias. As auditorias externas fornecem uma visão independente sobre a maturidade da segurança e sobre a

conformidade da instituição com normas como ISO/IEC 27001 [4], LGPD e regulamentações do Banco Central.

Tratamento dos resultados

Os resultados das auditorias devem ser documentados em relatórios formais, contendo as conformidades, não conformidades, vulnerabilidades identificadas, riscos associados e recomendações de correção. Cada apontamento deve possuir responsável, prazo de resolução e prioridade definida conforme o impacto ao negócio. As ações corretivas devem ser acompanhadas até sua conclusão e utilizadas como base para a melhoria contínua da política de segurança.

9.2 Revisão de Políticas e Procedimentos

Periodicidade e gatilhos

As políticas e procedimentos de segurança da informação devem ser revisados periodicamente para garantir que permaneçam adequados ao cenário tecnológico, às ameaças emergentes e às exigências legais e regulatórias. A ISO/IEC 27001 estabelece que a organização deve melhorar continuamente a adequação e a eficácia do sistema de gestão de segurança da informação, utilizando como base a política, os objetivos de segurança, os resultados de auditorias, a análise de incidentes e as ações corretivas [4].

Processo de revisão

A revisão da política deve ocorrer, no mínimo, uma vez por ano. Também deve ser realizada sempre que houver mudanças significativas na infraestrutura, implantação de novos sistemas, alteração nas normas do Banco Central, mudanças na LGPD, ocorrência de incidentes relevantes ou identificação de novas vulnerabilidades críticas. O processo de revisão deve envolver a direção, a equipe de TI, a equipe de segurança da informação, áreas administrativas e representantes das filiais.

Documentação e comunicação

Todas as alterações realizadas na política devem ser registradas em histórico de versões, contendo data, responsável, motivo da alteração e resumo das mudanças. Após cada atualização, a política deve ser comunicada aos colaboradores, prestadores de serviços e demais partes envolvidas. Como boa prática de mercado, especialistas da SentinelOne destacam que políticas de segurança não são documentos estáticos: elas devem ser revisadas periodicamente e atualizadas com base em feedback dos usuários, relatórios de incidentes e evolução das ameaças [17]. A SentinelOne também recomenda que políticas de segurança

sejam revisadas pelo menos uma vez por ano e sempre que houver mudanças significativas no ambiente tecnológico ou no cenário de ameaças [17].

Treinamento após revisões

Sempre que uma alteração relevante for aprovada, a BluCoop deve avaliar a necessidade de treinamento ou comunicação específica aos colaboradores. Mudanças relacionadas a acesso, senhas, uso de sistemas, tratamento de dados pessoais, resposta a incidentes ou uso de dispositivos corporativos devem ser acompanhadas de orientação formal, garantindo que todos compreendam suas responsabilidades.

9.3 Análise de Riscos

Metodologia de avaliação

A BluCoop deve adotar uma metodologia estruturada para análise de riscos de segurança da informação. O NIST SP 800-30 apresenta um processo de avaliação de riscos composto por quatro etapas principais: preparação da avaliação, realização da avaliação, comunicação dos resultados e manutenção da avaliação ao longo do tempo [12]. Essa abordagem permite identificar ameaças, vulnerabilidades, impactos e probabilidades, oferecendo suporte à tomada de decisão.

Identificação de ativos e ameaças

A análise de riscos deve considerar os ativos críticos da cooperativa, incluindo servidores da matriz, bancos de dados, sistemas financeiros, equipamentos de rede, conexões VPN, estações de trabalho, dados de cooperados, dados pessoais de colaboradores e informações sigilosas. Também devem ser consideradas ameaças como phishing, malware, ransomware, vazamento de dados, indisponibilidade de links WAN, falhas de energia, erro humano, uso indevido de credenciais e ataques direcionados a sistemas financeiros.

Avaliação de impacto e probabilidade

Cada risco identificado deve ser avaliado conforme sua probabilidade de ocorrência e seu impacto potencial sobre a confidencialidade, integridade e disponibilidade das informações. Riscos que possam afetar operações críticas, dados financeiros, dados pessoais ou serviços essenciais devem receber prioridade no tratamento. A classificação dos riscos deve apoiar decisões sobre controles técnicos, administrativos e físicos.

Tratamento dos riscos

Os riscos identificados devem ser tratados por meio de ações de mitigação, transferência, aceitação ou eliminação. A mitigação pode incluir aplicação de patches, reforço de autenticação, segmentação de rede, criptografia, backups, treinamento de usuários, revisão de contratos com fornecedores e melhoria dos controles de monitoramento. As decisões de tratamento devem ser registradas e aprovadas pelos responsáveis pela segurança da informação e pela direção.

Revisão contínua dos riscos

A análise de riscos deve ser revista pelo menos uma vez por ano ou sempre que ocorrerem mudanças relevantes, como implantação de novos sistemas, alteração na infraestrutura, contratação de novos fornecedores, identificação de vulnerabilidades críticas ou ocorrência de incidentes. A manutenção contínua da avaliação garante que o perfil de risco da BluCoop reflita sua realidade operacional [12].

9.4 Medição de Desempenho

Programa de métricas

A BluCoop deve estabelecer métricas e indicadores-chave de desempenho para avaliar a eficácia do programa de segurança da informação. O NIST SP 800-55 destaca que um programa de medição de segurança deve contar com apoio da alta direção, políticas e procedimentos claros e métricas quantificáveis alinhadas aos objetivos de segurança [13]. As métricas devem permitir acompanhar tendências, avaliar resultados e apoiar decisões de melhoria.

Indicadores recomendados

A cooperativa deve acompanhar indicadores como: número de incidentes reportados, tempo médio de resposta a incidentes, tempo médio de aplicação de patches críticos, quantidade de vulnerabilidades abertas, percentual de ativos atualizados, percentual de colaboradores treinados, taxa de sucesso de testes de restauração de backup, disponibilidade dos serviços críticos, tentativas de acesso não autorizado e quantidade de não conformidades identificadas em auditorias.

Monitoramento contínuo

A medição de desempenho deve ser integrada ao monitoramento contínuo da segurança. O NIST SP 800-137 define o monitoramento contínuo como uma estratégia para manter consciência permanente sobre vulnerabilidades, ameaças, controles de segurança e

riscos organizacionais [14]. Essa prática permite que a organização tome decisões mais rápidas e fundamentadas, ajustando controles conforme o ambiente muda.

Relatórios de desempenho

Os resultados das métricas devem ser consolidados em relatórios periódicos para a equipe de segurança da informação e para a direção. Esses relatórios devem apresentar a evolução dos indicadores, os riscos mais relevantes, as ações corretivas em andamento e as recomendações de melhoria. Sempre que possível, os resultados devem ser comparados com períodos anteriores para identificar tendências positivas ou negativas.

Uso dos resultados para melhoria contínua

As métricas, auditorias, análises de risco e registros de incidentes devem alimentar o ciclo de melhoria contínua da segurança da informação. A BluCoop deve utilizar esses dados para revisar controles, atualizar políticas, priorizar investimentos, melhorar treinamentos e fortalecer sua capacidade de prevenção, detecção, resposta e recuperação diante de incidentes.

Ao implantar auditorias periódicas, revisão de políticas, análise de riscos e medição de desempenho, a BluCoop estabelece um ciclo contínuo de avaliação e aprimoramento. Esse ciclo contribui para manter a política de segurança atualizada, reduzir vulnerabilidades, atender exigências legais e regulatórias e fortalecer a proteção das informações da cooperativa.

10 CONFORMIDADE LEGAL E REGULATÓRIA

Este capítulo estabelece as diretrizes para que a BluCoop cumpra obrigações legais e regulatórias relacionadas à segurança da informação e privacidade. Como cooperativa de crédito, a BluCoop deve alinhar seu programa de segurança às normas do Banco Central do Brasil (Bacen), às leis de proteção de dados pessoais e às demais leis bancárias aplicáveis.

10.1 Conformidade com Leis e Regulamentações

Resoluções do Banco Central

A política de segurança cibernética deve atender às resoluções do Bacen/Conselho Monetário Nacional que regem a segurança nas instituições financeiras. A Resolução CMN n.º 4.658/2018 obriga as instituições a implementar e manter uma política de segurança cibernética baseada em princípios que assegurem a confidencialidade, a integridade e a disponibilidade dos dados e sistemas de informação [1]. Essa política deve ser compatível com o porte, o perfil de risco, a complexidade das operações e a sensibilidade dos dados da instituição [1]. A resolução determina que a política inclua objetivos de segurança, procedimentos e controles para reduzir vulnerabilidades, controles de rastreabilidade, registro e análise de incidentes, diretrizes para testes de continuidade, classificação de dados e mecanismos de disseminação da cultura de segurança [1]. Exige-se ainda a elaboração de plano de ação e resposta a incidentes aprovado pela alta administração, a designação de um diretor responsável, a apresentação de relatório anual de incidentes e a divulgação da política aos empregados e prestadores de serviços terceirizados [1]. A instituição deve compartilhar informações sobre incidentes relevantes com o Bacen e outras instituições e manter documentação e contratos relacionados por pelo menos cinco anos [1].

Requisitos adicionais da Resolução BCB n.º 4.893/2021

Em 2021, a Resolução CMN 4.893/2021 revogou a Resolução 4.658 e reforçou a governança de segurança cibernética. Entre as obrigações estão: definição de responsabilidades da alta administração para a gestão de riscos cibernéticos, implementação de estratégia integrada de identificação, proteção, detecção, resposta e recuperação frente a incidentes, exigência de planos de continuidade de negócios que contemplem cenários de ataques cibernéticos e garantia de que serviços de terceiros (processamento, armazenamento de dados e computação em nuvem) atendam aos mesmos padrões de segurança [2]. Assim, a BluCoop deve acompanhar as atualizações regulatórias do Bacen e revisar sua política sempre que houver mudanças significativas.

Lei Geral de Proteção de Dados (LGPD)

A Lei n.º 13.709/2018 impõe que controladores e operadores adotem medidas técnicas e administrativas aptas a proteger os dados pessoais de acessos não autorizados e de situações acidentais ou ilícitas de destruição, perda, alteração ou comunicação [3]. Essas medidas devem ser observadas desde a concepção até a execução de produtos ou serviços [3]. A LGPD determina que incidentes de segurança que possam acarretar risco ou dano relevante aos titulares sejam comunicados à Autoridade Nacional de Proteção de Dados (ANPD) e aos titulares, indicando a natureza dos dados afetados, as medidas de segurança aplicadas, os riscos e as ações de mitigação [3]. Os sistemas utilizados para tratar dados pessoais devem atender aos requisitos de segurança e às boas práticas de governança [3]. A BluCoop precisa garantir que sua política e procedimentos estejam em conformidade com a LGPD, incluindo gestão de consentimento, direitos dos titulares, notificação de incidentes e registro das bases legais de tratamento.

Sigilo bancário e leis setoriais

A Lei Complementar 105/2001 determina que as instituições financeiras, incluindo cooperativas de crédito, preservem o sigilo de suas operações ativas e passivas e dos serviços prestados [16]. O dever de sigilo estende-se ao Bacen e aos órgãos de fiscalização e só pode ser afastado nas hipóteses previstas em lei, como comunicação de ilícitos penais às autoridades competentes ou mediante autorização judicial [16]. Essa lei reforça a necessidade de controles rígidos de acesso às informações financeiras dos cooperados e de procedimentos para atendimento de requisições legais. Outras leis setoriais, como a Lei Complementar 130/2009 (que institui o Sistema Nacional de Crédito Cooperativo) e a Lei n.º 4.595/1964 (que dispõe sobre a política e instituições monetárias e creditícias), atribuem ao Bacen a supervisão das cooperativas de crédito e devem ser observadas na governança da BluCoop.

Integração das obrigações

Para garantir conformidade, a BluCoop deve mapear suas obrigações legais e regulatórias, manter um inventário das normas aplicáveis e estabelecer processos de revisão contínua. A política de segurança deve listar as leis e normas que regem a operação da cooperativa, incluindo LGPD, resoluções do Bacen, leis de sigilo bancário e normas fiscais. As revisões periódicas devem incluir a verificação de mudanças legislativas e a adequação dos controles internos.

10.2 Gerenciamento de Vulnerabilidades e Patches

Processo de gerenciamento de vulnerabilidades

A BluCoop deve implementar um processo estruturado para identificar, avaliar e corrigir vulnerabilidades em sistemas e aplicações. De acordo com o NIST SP 800-40, o patch management empresarial envolve identificar, priorizar, adquirir, instalar e verificar patches, atualizações e upgrades em toda a organização [15]. Esse processo precisa de apoio da alta direção e deve ser considerado custo de operação, pois reduz a probabilidade de compromissos, vazamentos e interrupções [15]. A cooperativa deve realizar avaliações regulares de vulnerabilidades, manter inventário atualizado dos ativos e softwares e classificar as vulnerabilidades conforme o risco para priorizar a aplicação de correções.

Princípios de patch management

O NIST recomenda adotar princípios que reduzam o risco e a complexidade do patching: (i) reconhecer que problemas decorrentes de patches são inevitáveis e preparar-se para enfrentá-los, tornando a organização mais resiliente [15]; (ii) simplificar a tomada de decisões, planejando previamente respostas a novas vulnerabilidades [15]; (iii) depender de automação para lidar com o grande volume de ativos, vulnerabilidades e patches, inclusive em situações de emergência [15]; e (iv) iniciar melhorias imediatamente, mesmo que mudanças estruturais demandem tempo [15]. A BluCoop deve utilizar ferramentas de gestão de vulnerabilidades, automatizar a aplicação de patches sempre que possível e documentar exceções e justificativas para eventuais adiamentos.

Redução de vulnerabilidades e inventário de ativos

Um programa eficaz deve diminuir o número de vulnerabilidades introduzidas no ambiente por meio de práticas como hardening de software (remoção de funcionalidades desnecessárias e aplicação do princípio do menor privilégio), aquisição de software desenvolvido com práticas de segurança, parceria com fornecedores que liberam patches rapidamente e adoção de serviços gerenciados sempre que viável [15]. A BluCoop também deve manter inventários atualizados de softwares e ativos (incluindo servidores, dispositivos de rede, equipamentos de filiais, IoT e contêineres), utilizando automação para descobri-los e atualizar suas características [15]. Inventários contínuos permitem orientar a priorização de patches conforme a criticidade dos ativos para o negócio [15].

Ciclo de correção e teste

Antes de aplicar patches em produção, a cooperativa deve testar as atualizações em ambiente controlado para identificar possíveis impactos operacionais. A política deve estabelecer janelas de manutenção, procedimentos de rollback em caso de falha, critérios de

aprovação e mecanismos de comunicação aos usuários sobre indisponibilidades programadas. Após a aplicação, a equipe de TI deve verificar a instalação e atualizar registros de configuração.

Integração com a governança

O gerenciamento de vulnerabilidades e patches deve estar alinhado ao sistema de gestão de segurança da informação da BluCoop. As métricas definidas na seção 8 devem incluir indicadores como tempo médio para aplicação de patches, taxa de correções bem-sucedidas, percentual de ativos atualizados e número de vulnerabilidades críticas pendentes. Relatórios periódicos devem ser apresentados à diretoria para apoiar a tomada de decisões e demonstrar conformidade com os regulamentos.

11 RESPONSABILIDADES

As responsabilidades relacionadas à segurança da informação na BluCoop são definidas com base em sua estrutura organizacional, com abrangência ampla, desde a alta direção até os cooperados e parceiros externos. A clareza dessas atribuições é fundamental para garantir a proteção dos dados financeiros dos cooperados, a continuidade operacional entre a matriz e as filiais, e a conformidade com os requisitos regulatórios do setor de crédito cooperativo.

11.1 Direção

A Direção da BluCoop é responsável pelo compromisso institucional com a segurança da informação, garantindo que os recursos humanos, tecnológicos e financeiros necessários sejam alocados de forma adequada. Compete à alta gestão aprovar e revisar esta Política de Segurança da Informação, assegurar seu alinhamento com os objetivos estratégicos da cooperativa e zelar pelo cumprimento das obrigações regulatórias impostas pelo Banco Central do Brasil e pelo sistema cooperativista. A Direção também é responsável por promover uma cultura organizacional orientada à proteção da informação em todas as unidades da cooperativa.

11.2 Equipe de Tecnologia da Informação

A equipe de Tecnologia da Informação da BluCoop é responsável pela implementação, operação e monitoramento dos controles técnicos de segurança definidos nesta PSI. Suas atribuições compreendem a administração da infraestrutura de rede, bem como a gestão de acessos, a manutenção dos ambientes em nuvem utilizados pela cooperativa, o monitoramento de incidentes e atualizações de segurança. Também compete a essa equipe garantir a disponibilidade, integridade e confidencialidade dos sistemas críticos, especialmente aqueles que suportam as operações financeiras e o atendimento aos cooperados.

11.3 Equipe de Segurança da Informação

A equipe de Segurança da Informação é responsável pela definição, revisão e supervisão das políticas, normas e procedimentos relativos à proteção dos ativos de informação da BluCoop. Cabe a essa equipe conduzir análises de risco, coordenar respostas a incidentes de segurança, realizar auditorias internas, acompanhar vulnerabilidades nos sistemas e orientar as demais áreas quanto às boas práticas de segurança. Adicionalmente,

atua como interlocutora junto a órgãos reguladores e parceiros externos em situações que envolvam a segurança das informações da cooperativa e de seus cooperados.

11.4 Colaboradores

Todos os colaboradores da cooperativa, independentemente do cargo, função ou unidade em que atuem, têm responsabilidade direta na proteção das informações às quais têm acesso. É dever de cada colaborador utilizar os sistemas e recursos tecnológicos corporativos de forma responsável e em conformidade com as diretrizes desta PSI, proteger credenciais de acesso, evitar o compartilhamento indevido de informações sensíveis e reportar imediatamente qualquer incidente, suspeita de violação ou comportamento irregular aos canais oficiais de segurança. O descumprimento dessas responsabilidades sujeita o colaborador às medidas disciplinares previstas nos normativos internos da cooperativa.

11.5 Cooperados

Os cooperados da BluCoop também desempenham papel relevante na segurança da informação, especialmente no que diz respeito ao uso dos canais digitais disponibilizados pela cooperativa. É de responsabilidade do cooperado manter suas credenciais de acesso em sigilo, não compartilhar dados pessoais ou financeiros por meios não oficiais, e comunicar à BluCoop qualquer suspeita de uso indevido de seus dados ou acesso não autorizado às suas contas. A cooperativa, por sua vez, compromete-se a orientar seus cooperados sobre práticas seguras de uso dos serviços financeiros digitais.

11.6 Fornecedores e Parceiros Externos

Fornecedores, prestadores de serviço e demais parceiros que tenham acesso a sistemas, dados ou infraestrutura da BluCoop estão sujeitos às diretrizes de segurança da informação estabelecidas nesta PSI e devem cumprir os requisitos definidos nos contratos firmados com a cooperativa. Cabe à BluCoop exigir evidências de conformidade e avaliar periodicamente os riscos associados a terceiros com acesso a informações sensíveis, adotando medidas contratuais e técnicas para mitigar eventuais vulnerabilidades introduzidas por essa cadeia de parceiros.

REFERÊNCIAS

- [1] BANCO CENTRAL DO BRASIL. Resolução CMN nº 4.658, de 26 de abril de 2018. Dispõe sobre a política de segurança cibernética e sobre os requisitos para a contratação de serviços de processamento e armazenamento de dados e de computação em nuvem. Brasília, DF: Banco Central do Brasil, 2018.
- [2] BANCO CENTRAL DO BRASIL. Resolução CMN nº 4.893, de 26 de fevereiro de 2021. Dispõe sobre a política de segurança cibernética e sobre os requisitos para a contratação de serviços de processamento e armazenamento de dados e de computação em nuvem pelas instituições financeiras. Brasília, DF: Banco Central do Brasil, 2021.
- [3] BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais (LGPD). Brasília, DF: Presidência da República, 2018.
- [4] INTERNATIONAL ORGANIZATION FOR STANDARDIZATION; INTERNATIONAL ELECTROTECHNICAL COMMISSION. ISO/IEC 27001:2022: Information security, cybersecurity and privacy protection. 3. ed. Geneva: ISO, 2022.
- [5] ASSOCIAÇÃO BRASILEIRA DE NORMAS TÉCNICAS. ABNT NBR ISO/IEC 27002: Segurança da informação, segurança cibernética e proteção à privacidade. Rio de Janeiro: ABNT, 2022.
- [6] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Security and Privacy Controls for Information Systems and Organizations: NIST SP 800-53 Rev. 5. Gaithersburg: NIST, 2020.
- [7] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guidelines for Media Sanitization: NIST SP 800-88 Rev. 1. Gaithersburg: NIST, 2014.
- [8] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guidelines on Firewalls and Firewall Policy: NIST SP 800-41 Rev. 1. Gaithersburg: NIST, 2009.
- [9] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guide to SSL VPNs: NIST SP 800-113. Gaithersburg: NIST, 2008.
- [10] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guide to Computer Security Log Management: NIST SP 800-92. Gaithersburg: NIST, 2006.

-
- [11] CENTER FOR INTERNET SECURITY. CIS Benchmarks. CIS, 2024. Disponível em: <https://www.cisecurity.org/cis-benchmarks>. Acesso em: 6 jun. 2026.
- [12] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guide for Conducting Risk Assessments: NIST SP 800-30 Rev. 1. Gaithersburg: NIST, 2012.
- [13] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Performance Measurement Guide for Information Security: NIST SP 800-55 Rev. 1. Gaithersburg: NIST, 2008.
- [14] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Information Security Continuous Monitoring: NIST SP 800-137. Gaithersburg: NIST, 2011.
- [15] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. Guide to Enterprise Patch Management Planning: NIST SP 800-40 Rev. 4. Gaithersburg: NIST, 2022.
- [16] BRASIL. Lei Complementar nº 105, de 10 de janeiro de 2001. Dispõe sobre o sigilo das operações de instituições financeiras. Brasília, DF: Presidência da República, 2001.
- [17] SENTINELONE. Effective Endpoint Security Policy in 2026. SentinelOne, 2024. Disponível em: <https://www.sentinelone.com/cybersecurity-101/endpoint-security/endpoint-security-policy/>. Acesso em: 6 jun. 2026.
- [18] BANCO CENTRAL DO BRASIL. Resolução BCB nº 85, de 8 de abril de 2021. Regulamenta as diretrizes sobre segurança cibernética, continuidade de negócios e comunicação de incidentes relevantes das instituições autorizadas a funcionar pelo Banco Central do Brasil. Brasília, DF: Banco Central do Brasil, 2021. Disponível em: <https://www.bcb.gov.br/estabilidadefinanceira/exibenormativo?tipo=Resolu%C3%A7%C3%A3o%20BCB&numero=85>. Acesso em: 6 jun. 2026.
- [19] NATIONAL INSTITUTE OF STANDARDS AND TECHNOLOGY. The NIST Cybersecurity Framework (CSF) 2.0. Gaithersburg: NIST, 2024. Disponível em: <https://doi.org/10.6028/NIST.CSWP.29>. Acesso em: 6 jun. 2026.

GLOSSÁRIO

Este glossário reúne os principais termos técnicos utilizados ao longo desta Política de Segurança da Informação, com o objetivo de facilitar a compreensão dos conceitos por todos os colaboradores da BluCoop, independentemente de sua área de atuação.

Access Point: Dispositivo que permite a conexão de equipamentos sem fio à rede local. Deve ser configurado com autenticação e criptografia adequadas para evitar acessos não autorizados.

ANPD (Autoridade Nacional de Proteção de Dados): Órgão responsável por fiscalizar e orientar o cumprimento da LGPD no Brasil. Recebe comunicações de incidentes que envolvam dados pessoais com risco aos titulares.

Autenticação: Processo de confirmação da identidade de um usuário, normalmente por meio de login e senha, token, biometria ou autenticação em duas etapas.

Backup: Cópia de segurança de dados, arquivos ou sistemas, utilizada para restaurar informações em caso de perda, exclusão acidental, falha técnica, ataque cibernético ou desastre.

Banco Central do Brasil (Bacen): Órgão regulador do sistema financeiro brasileiro. Como cooperativa de crédito, a BluCoop deve observar as normas emitidas pelo Bacen e pelo Conselho Monetário Nacional.

CIS Benchmarks: Guias de configuração segura publicados pelo Center for Internet Security, com recomendações específicas para sistemas operacionais, aplicações e equipamentos de rede.

Criptografia: Técnica que transforma uma informação em formato ilegível para pessoas não autorizadas. Mesmo que os dados sejam interceptados, não poderão ser compreendidos sem a chave correta.

Disponibilidade: Princípio da segurança da informação que garante que sistemas, dados e serviços estejam acessíveis quando necessários.

DMZ (Zona Desmilitarizada): Segmento de rede isolado, situado entre a rede interna e a internet, utilizado para hospedar serviços que precisam ser acessíveis externamente sem expor a rede interna.

DNS (Domain Name System): Serviço que traduz nomes de domínio em endereços IP. Permite acessar sistemas por nome em vez de pelo endereço numérico.

Firewall: Dispositivo ou software que controla o tráfego de rede com base em regras definidas, permitindo ou bloqueando conexões entre zonas de rede.

Hardening: Processo de configuração segura de sistemas, servidores e equipamentos de rede, que inclui a remoção de serviços desnecessários, alteração de senhas padrão e aplicação de configurações que minimizem vulnerabilidades.

IDS / IPS: Sistemas de Detecção (IDS) e Prevenção (IPS) de Intrusão. Monitoram o tráfego de rede em busca de padrões suspeitos ou ataques conhecidos, gerando alertas ou bloqueando automaticamente o tráfego malicioso.

Incidente de segurança: Evento que compromete ou pode comprometer a confidencialidade, integridade ou disponibilidade das informações.

Integridade: Princípio da segurança da informação que garante que os dados estejam corretos, completos e não sejam alterados indevidamente.

ISO/IEC 27001: Norma internacional que define requisitos para um Sistema de Gestão de Segurança da Informação.

LGPD (Lei Geral de Proteção de Dados): Lei brasileira nº 13.709/2018 que regula o tratamento de dados pessoais.

Log: Registro automático de eventos gerado por sistemas, dispositivos e aplicações. Essencial para auditoria, diagnóstico de falhas e investigação de incidentes.

Malware: Software malicioso criado para causar danos, roubar dados, obter acesso indevido ou comprometer sistemas. Inclui vírus, spyware, trojans e ransomware.

Menor privilégio: Princípio segundo o qual cada usuário deve ter apenas as permissões necessárias para realizar suas atividades, reduzindo o risco de acesso indevido.

NIST: Instituto norte-americano que publica guias e boas práticas de segurança da informação amplamente adotadas como referência.

Nobreak (UPS): Dispositivo de alimentação ininterrupta que mantém o fornecimento de energia aos equipamentos durante falhas ou instabilidades na rede elétrica.

Patch: Correção ou atualização aplicada a um software, sistema ou equipamento para resolver falhas, melhorar funcionalidades ou corrigir vulnerabilidades de segurança.

Patch management: Processo de identificar, priorizar, aplicar e verificar atualizações e correções em sistemas e softwares.

Phishing: Golpe em que o atacante tenta enganar uma pessoa para obter informações sensíveis, como senhas, dados bancários ou códigos de acesso, geralmente por e-mail, mensagem ou site falso.

Ransomware: Tipo de malware que bloqueia ou criptografa dados e exige pagamento para liberá-los, podendo causar indisponibilidade de sistemas e perda de informações.

Rollback: Procedimento de retorno a uma versão anterior de um sistema ou configuração, utilizado quando uma atualização ou patch causa problemas e precisa ser desfeito.

Segmentação de rede: Divisão da rede em partes menores e separadas. Limita o acesso entre áreas diferentes e reduz o impacto caso uma parte da rede seja comprometida.

SIEM: Security Information and Event Management. Plataforma que coleta e correlaciona eventos de segurança de múltiplas fontes para detectar incidentes e gerar alertas em tempo real.

SLA (Acordo de Nível de Serviço): Contrato que define os níveis mínimos de qualidade e disponibilidade de um serviço prestado por fornecedor externo.

TLS (Transport Layer Security): Protocolo criptográfico que protege a comunicação pela internet e redes internas, garantindo confidencialidade e integridade dos dados transmitidos.

VoIP (Voice over IP): Tecnologia de comunicação por voz transmitida sobre redes IP. Na BluCoop, o servidor VoIP é ativo crítico que deve ser protegido por controles específicos de segurança.

VPN (Virtual Private Network): Canal criptografado que permite aos colaboradores em trabalho remoto acessarem a rede interna da BluCoop de forma segura.

Vulnerabilidade: Falha ou fraqueza em um sistema, processo, configuração ou comportamento humano que pode ser explorada por uma ameaça.

WAN (Wide Area Network): Rede de longa distância usada para conectar unidades geograficamente separadas. Na BluCoop, conecta a matriz às filiais.